APPLICATION SECURITY ASSESSMENT / PUBLIC EDITION V1.1

Project Lumen
Security Assessment

Síntese sanitizada de avaliação realmente executada: autenticação, multi-tenancy, segurança de agentes, SAST, SCA e governança de CI/CD.

AVALIAÇÃO EXECUTADA / EDIÇÃO PÚBLICA

Projeto Lumen é um codinome público fictício para apresentar a metodologia de uma avaliação de aplicação efetivamente realizada. O código, as capturas, os identificadores, as contagens detalhadas e as evidências brutas permanecem privados. Ilustrações são expressamente marcadas como fictícias.

TIPO	Case profissional sanitizado / evidências restritas
AUTOR	Gabriel Barbosa — Cybersecurity Engineer
ABORDAGEM	Evidence First · Production Safe
CLASSIFICAÇÃO	Público · Identificadores e evidências privadas omitidos

> **REGRA DE PUBLICAÇÃO**
>
> Descrever somente técnicas e categorias comprovadas na avaliação privada; ocultar arquitetura interna, paths proprietários, detalhes exploráveis, achados não divulgados, logs e controles específicos do ambiente.

02 / EXECUTIVE SUMMARY

Sumário Executivo

O assessment original foi realmente executado; esta edição publica seu método e resultados em categorias, sem revelar a aplicação.

Foi realizada uma avaliação direcionada de segurança de aplicação sobre um repositório privado, combinando SAST, SCA, busca por segredos e leitura manual de controles de identidade, multi-tenancy, agentes de IA, integrações e CI/CD. A execução ocorreu sem alteração de código ou ambiente de produção. Neste relatório, Projeto Lumen é somente o codinome editorial.

EXECUÇÃO COMPROVÁVEL NO ACERVO PRIVADO

Varreduras Semgrep e Trivy, revisão contextual dos resultados, inspeção direcionada de código e testes existentes, além de análise de configuração.

LIMITES DE PUBLICAÇÃO

Capturas de scanner, paths, endpoints, variáveis internas, detalhes exploráveis e registros originais não são publicados. A prova primária permanece no acervo restrito do assessment.

RESULTADOS APRESENTADOS EM CATEGORIAS

DIMENSÃO	CONCLUSÃO DELIMITADA
Autenticação / boot	Um risco dependente de configuração foi identificado no código; estado implantado não foi confirmado.
Dependências	O SCA reportou advisories que exigiam atualização e validação de alcance.
AI / agent tools	Fronteira entre credencial e confiança administrativa analisada como revisão de design.
CI / supply chain	Oportunidades de hardening documentadas; sem alegar comprometimento.
Controles existentes	Foram identificados controles e testes direcionados em diferentes camadas.

CONCLUSÃO DEFENSÁVEL

Houve trabalho técnico real, não uma simulação integral. O PDF público restringe o nível de detalhe por confidencialidade: não certifica produção nem atribui exploração, invasão ou falha ativa ao ambiente privado.

03 / PUBLICATION BOUNDARY

Limites de Publicação

Metodologia real e resultados por categoria; identificadores e evidências sensíveis não transferidos à edição pública.

ELEMENTO	TRATAMENTO NA EDIÇÃO PÚBLICA
Identificação do produto	Codinome fictício “Projeto Lumen”; não corresponde ao nome real da aplicação.
Empresa / cliente	Sem identificação do proprietário do sistema ou destinatário da auditoria.
Arquitetura / componentes	Somente modelo pedagógico genérico criado para ilustrar trust boundaries.
Código / infraestrutura	Sem paths reais, detalhes de configuração, prints de repositório ou nomes de recursos.
Ferramentas e método	Nomes de ferramentas e técnicas foram preservados, pois são genéricos e pertinentes.
Achados	Apenas categorias e grau de confiança; sem exploit path, versions exatas, chaves ou trechos internos.
Evidências	Capturas, contagens completas, logs, comandos de scanner e IDs permanecem sob guarda privada.
Aprovação	Autoria individual; nenhum aceite ou assinatura de terceiros é alegado.

COMO INTERPRETAR O DOCUMENTO

REALMENTE EXECUTADO

Varreduras e revisão manual foram realizadas na avaliação originária, conforme os registros privados; conclusões são gerais, sem detalhes de sistemas.

ILUSTRAÇÕES FICTÍCIAS

Fluxos desenhados nesta edição servem ao ensino. Não representam a arquitetura original nem substituem provas do ambiente real.

LIMITE DE VERIFICABILIDADE

O leitor externo pode avaliar método, coerência e documentação, mas não pode reproduzir os achados internos com este PDF. Não apresentamos métricas fictícias como resultados de scanner.

04 / PERFORMED ASSESSMENT

Escopo, Método e Execução

Ferramentas executadas em avaliação autorizada, complementadas por leitura de código sem ação destrutiva.

01 Escopo
02 SAST/SCA
03 Revisão
04 Triagem
05 Plano

ATIVIDADES EFETIVAMENTE DOCUMENTADAS

TÉCNICA	TRABALHO REALIZADO	LIMITAÇÃO
Semgrep / SAST	Varreduras gerais, perfil de regras OWASP e busca por segredos; alerta classificado manualmente.	Cobertura sujeita a linguagens, regras aplicáveis e limites de tamanho.
Trivy / SCA	Análise de dependências e advisories, incluindo distinção entre escopo principal e dev/test.	Presença em lockfile não prova exploração.
Code review	Autenticação, sessão, RBAC, tenant isolation, agent tool-use e fronteiras de confiança.	Estado de produção e integrações externas não reproduzidos integralmente.
CI/CD review	Análise de workflow, referências de ações, permissões e controles de supply chain.	Hardening sugerido sem implementação por este assessment.
Testes e evidência	Inspeção direcionada de testes existentes para corroborar caminhos de decisão.	Suíte completa da aplicação não foi executada neste trabalho.

SAST + ANÁLISE HUMANA

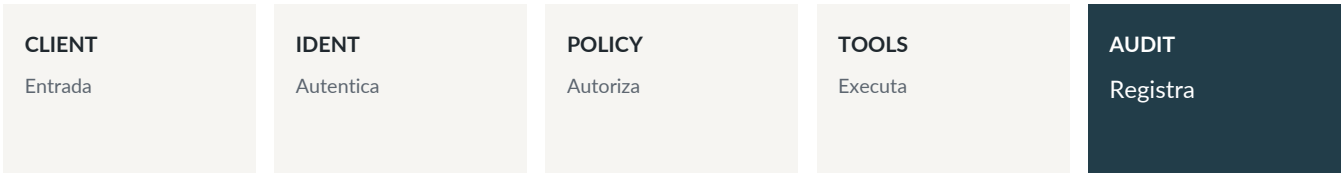
Diferenciar scanner finding, controle no código e comportamento validado evita classificações exageradas. Observação em código não equivale a validação de produção.

05 / ILLUSTRATIVE MODEL

Modelo Conceitual Fictício

Diagrama reconstruído do zero para explicar conceitos, não a arquitetura da aplicação privada avaliada.

EXEMPLO PEDAGÓGICO



A avaliação originária examinou separação entre autenticação, autorização e ações do agente. O fluxo acima é uma representação genérica criada para esta publicação. Os nomes dos blocos e sua ordem não permitem inferir a implementação, os provedores nem a topologia do software auditado.

FRONTEIRAS DE CONFIANÇA RELEVANTES

FRONTEIRA	QUESTÃO DE SEGURANÇA
Cliente / API	Como a identidade é estabelecida e validada antes de invocar operação protegida?
Principal / tenant	Uma identidade autenticada pode cruzar escopos entre organizações?
Modelo / ferramenta	O modelo pode pedir ação; quem impõe autorização e limites?
Build / deploy	Que evidência vincula código revisado, dependências e artefato promovido?

NÃO REVELA ARQUITETURA

Este desenho ilustra perguntas de revisão conhecidas em AppSec. Não contém endpoints, serviços, integrações, permissões específicas nem detalhes do ambiente privado.

06 / SANITIZED FINDINGS

Matriz de Achados Sanitizados

Classes de resultados da avaliação efetiva, sem detalhes que permitam identificar ou explorar o alvo.

CLASSE	ACHADO EM NÍVEL PÚBLICO	ESTADO / LIMITAÇÃO
AUTH	Caminho de autenticação com comportamento dependente de configuração.	Identificado no código; condição do deploy não comprovada.
SCA	Advisories de dependências com plano de atualização e reteste.	Detectados por scanner; reachability não demonstrada.
SUPPLY	Itens de hardening de dependências e pipeline.	Recomendação; não é incidente confirmado.
AI TRUST	Interação entre credencial válida e escopo de ações administrativas.	Design review; escalada indevida não demonstrada.
SAST TRIAGE	Um alerta exigiu revisão dos controles efetivos de resposta de conteúdo.	Classificado após análise manual; sem explorar produção.

POR QUE NÃO PUBLICAMOS OS DETALHES?

RESULTADO REAL

As categorias e limitações acima decorrem da avaliação originária realizada. Contagem detalhada, arquivo, código, endpoint, stack e exploração ficam restritos.

SEGURANÇA DA PUBLICAÇÃO

Divulgar um caminho exato de falha ou configuração sensível poderia expor indevidamente uma aplicação ainda em manutenção.

NÃO INVENTAR PROVA

Não foram executados novos scans no “Projeto Lumen” fictício. Não atribuímos resultado de laboratório simulado ao produto real nem afirmamos exploração ou compromissos.

07 / IDENTITY & TENANCY

Identidade, Acesso e Isolamento

Revisão direcionada de caminhos de autenticação e autorização existentes no código privado.

COMPONENTES DA ANÁLISE

WHO	WHAT	WHICH	SCOPE	DECIDE
Principal	Operação	Recurso	Tenant	Política

A revisão examinou controles de sessão, RBAC, escopo multi-tenant e comportamento de autenticação em configuração de implantação. O código e testes revisados forneceram evidência de controles existentes, mas a avaliação não equivale a teste completo de produção.

CRITÉRIOS DE VALIDAÇÃO DOCUMENTADOS

DIMENSÃO	O QUE FOI INSPECIONADO / QUALIFICADO
Sessão e identidade	Tratamento de sessão válida, inválida e adulterada nos caminhos revisados.
RBAC / objeto	Regras de papel, comportamento deny-by-default e escopo de acesso.
Isolamento de tenant	Propagação de contexto e testes direcionados contra acesso entre organizações.
Configuração de autenticação	Possibilidade de inicialização de rota protegida em condição de configuração inadequada.

> **RISCO CONDICIONAL**
>
> Um comportamento possível no código não implica que a mesma condição esteja ativa na produção. A correção deve incluir fail-closed, verificação de configuração e testes de regressão em ambiente autorizado.

08 / AI / AGENT SECURITY

Segurança de Agentes e Ferramentas

A avaliação examinou limites entre credenciais, decisão de IA e execução de ferramentas.

INPUT	MODEL	POLICY	APPROVE	TOOL
Não confiável	Propõe	Decide	Se crítico	Executa

CONTROLES E RISCOS REVISADOS

CONTROLE	EVIDÊNCIA QUALIFICADA SEM DETALHE INTERNO
Fronteira modelo / executor	Verificado no código o uso de autorização determinística fora do texto do LLM.
Permissão de ferramenta	Critérios de exposição, negação e aprovação para classes distintas de ações.
Ações críticas	Observados controles adicionais de aprovação para efeitos sensíveis.
Credencial e trust	Fronteira de design entre posse de credencial e nível de autoridade analisada.
Egress / ferramentas	Buscas dirigidas por caminhos de requisição arbitrária; ausência de exploração não alegada.

REVISÃO DE DESIGN

Uma credencial pode identificar um consumidor, mas isso não determina por si só o nível mínimo de privilégio adequado a cada integração.

O QUE NÃO FOI PROVADO

Não se atribui escalada de privilégio ao alvo privado nem segurança universal às ferramentas inspecionadas.

INVARIANTE

MODEL OUTPUT ≠ AUTHORIZATION. A implementação privada não é reproduzida; o princípio técnico observado é descrito apenas em alto nível.

09 / SAST & CODE REVIEW

Análise Estática e Triagem Manual

Execuções de Semgrep e revisão contextual realizadas no assessment privado.

ESCOPO EXECUTADO	RESULTADO PUBLICÁVEL	LIMITE
SAST geral	Alertas identificados e classificados após leitura do código.	Sem divulgar arquivos ou localização exata.
Perfil OWASP	Finding de ferramenta ≠ vulnerabilidade explorável; categorias triadas.	Só regras aplicáveis ao repositório foram executadas.
Secrets scan	Nenhuma correspondência reportada nos arquivos cobertos.	Não constitui garantia de inexistência.
Revisão manual	Um alerta de saída HTTP foi tratado à luz de validação de conteúdo e headers.	Resultado limitado ao código e testes consultados.

DEMONSTRAÇÃO DO RACIOCÍNIO

SCAN	SOURCE	FLOW	DEFENSE	STATE
Sinal	Caminho	Contexto	Mitigação	Classificar

A revisão não contou simplesmente alertas automatizados. Primeiro identificou o contexto de execução, depois inspecionou controles adjacentes e classificou se o sinal representava risco técnico confirmado, necessidade de hardening, fixture ou falso positivo no escopo observado.

CONTROLE DE QUALIDADE

Regras disponíveis e regras executadas não são números equivalentes. Também é necessário registrar limites de arquivo e de linguagem. A íntegra das saídas não foi publicada por confidencialidade.

10 / SCA & SUPPLY CHAIN

Dependências e Cadeia de Suprimentos

Varredura de dependências realmente executada e priorização técnica documentada.

FONTE / ETAPA	O QUE AVALIAMOS
SCA por Trivy	Inventário de advisories no conjunto principal e com bibliotecas de desenvolvimento/teste.
Severidade do scanner	Advisories classificados por criticidade sem concluir exploitabilidade automática.
Lockfile	Verificação de versões declaradas e dependências transitivas; código vulnerável pode não ser alcançável.
Mitigação	Recomendação de atualização, regeneração de lockfile e regressão compatível.
Cadeia de suprimentos	Política de dependências e execução controlada de scripts de build.

O QUE ESTÁ PROVADO E O QUE NÃO ESTÁ

DETECTADO NO SCAN

Um conjunto de componentes e advisories foi detectado nos insumos analisados. Relatório bruto permanece restrito.

AINDA DEPENDE DE TESTE

Reachability, pré-condições de exploração, superfície ativa e ausência de regressão após atualização.

SEM EXPOSIÇÃO DE VERSÕES

O documento não revela bibliotecas ou versões internas afetadas nem identifica CVEs presentes no software privado. Exemplos específicos de CVE, quando públicos, devem pertencer a labs autônomos.

11 / DEVSECOPS & CI/CD

Segurança no Pipeline de Entrega

O workflow privado foi revisado; controles de branch são prova separada no repositório público.

SOURCE	WORKFLOW	TESTS	ARTIFACT	GOVERN
Commit	Regras	Verificação	Build	Merge

CATEGORIAS DE REVISÃO EXECUTADA

CONTROLE	O QUE FOI AVALIADO
GitHub Actions	Referências de ações, permissões de token e controles de execução.
Qualidade de pipeline	Presença de testes, timeout, regras de dependência e verificação de build.
Supply chain	Referências de componentes e políticas recomendadas para instalação mais restrita.
Evidência de deploy	O código do repositório não comprova sozinho artefato efetivamente implantado.

EVIDÊNCIA PÚBLICA COMPLEMENTAR

CI DO PORTFÓLIO

O GitHub Actions deste portfólio executa checks automatizados e publica resultados verificáveis.

REGRAS DA MAIN

Um ruleset ativo e um teste negativo de PR demonstram bloqueio de merge no repositório pessoal, separado da avaliação privada.

LIMITES DE ATRIBUIÇÃO

Não reproduzimos YAML, status checks nem pipeline corporativo. O caso público [Branch Protection Validation] é uma demonstração independente no próprio GitHub de portfólio.

12 / EVIDENCE CLASSIFICATION

Evidências e Estados de Confiança

Cada conclusão deve indicar de onde vem: scanner, código, testes revisados ou comportamento de produção.

ESTADO	DEFINIÇÃO PARA ESTE CASE
OBSERVED	Uma condição aparece diretamente na saída de scanner ou no código inspecionado.
VERIFIED	A condição foi corroborada por fonte ou teste adicional dentro do escopo disponível.
INFERRED	Há suporte indireto, mas falta comprovação de algum elemento da conclusão.
UNVERIFIED	A avaliação não dispõe de prova suficiente para essa afirmação.
NOT EXECUTED	Não foi realizada uma validação adicional descrita apenas como recomendação.

MANIFESTO DE EVIDÊNCIAS (NÍVEL PÚBLICO)

FONTE	REGISTRO PRESERVADO PRIVADAMENTE
Semgrep	Versão/família da regra, arquivos no escopo e saída de findings.
Trivy	Dependências e advisories identificados nos insumos examinados.
Manual review	Trechos de código, referências a controles e teste consultado.
Configuração	Condição de boot, controle e contexto de avaliação.
CI/CD	Referências das políticas de workflow, sem copiar o YAML privado.

> **NÃO CONFUNDIR CAMADAS**
>
> Os resultados do scan e da revisão foram reais e documentados. O ambiente produtivo não foi reproduzido; portanto, achados condicionais permanecem explicitamente condicionais.

13 / REMEDIATION & RETEST

Plano de Tratamento e Reteste

Recomendações reais em categorias sanitizadas; correção e reteste não são alegados como concluídos.

PRIORIDADE	RECOMENDAÇÃO PUBLICÁVEL
Imediata · Autenticação	Garantir inicialização fail-closed quando configuração de proteção obrigatória estiver ausente.
Imediata · Dependências	Atualizar componentes priorizados pelo SCA; validar compatibilidade e regressão.
Curto prazo · CI/CD	Revisar permissões mínimas dos workflows e referências de ações externas.
Curto prazo · Supply chain	Fortalecer política de dependências e controle de scripts de instalação.
Médio prazo · AI	Formalizar matriz credencial → principal → nível de confiança → ferramentas → aprovação.
Médio prazo · Observabilidade	Correlacionar decisões e efeitos das ferramentas sem armazenar segredo ou dados sensíveis.

CRITÉRIOS DE ACEITE QUE PROPOMOS

CONTROLE DE ACESSO

Cenários positivos e negativos de autenticação devem passar após a correção, com evidência de configuração adequada.

REGRESSÃO SEGURA

Testes de dependências e pipeline devem confirmar que a mudança não quebrou operações autorizadas.

ESTADO DO TRABALHO

A avaliação original produziu propostas de remediação; não alegamos que essas alterações foram executadas ou que o risco desapareceu. Nova prova depende de reteste autorizado.

14 / CONCLUSION & AUTHORSHIP

Conclusão e Limitações

O trabalho técnico foi real; a edição pública não transforma informação restrita em conteúdo explorável.

Este estudo documenta a metodologia e resultados sanitizados de um assessment efetivamente realizado: Semgrep/SAST, Trivy/SCA, leitura manual de autenticação, isolamento multi-tenant, segurança de agentes e avaliação de supply chain/CI-CD. As evidências operacionais permanecem confidenciais, de modo que o leitor pode inspecionar a qualidade do raciocínio, mas não reproduzir os achados privados.

LIMITAÇÕES E RESPONSABILIDADE

LIMITE	DECLARAÇÃO
Identidade do alvo	“Projeto Lumen” é codinome público fictício; não identifica o software examinado.
Prova primária restrita	Logs, screenshots, relatórios brutos, trechos de código e contagens detalhadas não publicados.
Produção não verificada	O assessment foi focado em código; não valida configuração efetiva de deploy.
Suíte incompleta	Testes específicos foram inspecionados; suíte completa não executada por esta avaliação.
Exploração não demonstrada	Scanner, advisory ou hipótese não equivalem a exploração confirmada.
Nenhuma aprovação presumida	Sem assinatura ou endosso atribuído a empresas, clientes ou revisores externos.

COMO APRESENTAR EM ENTREVISTA

“Executei um assessment autorizado de aplicação usando SAST, SCA e revisão manual; produzi uma versão pública com os métodos e as conclusões possíveis, sem publicar resultados exploráveis ou informações confidenciais.”

AUTORIA

Gabriel Barbosa · Cybersecurity Engineer
Application Security · AI Security · SAST/SCA · DevSecOps